

Étude des services ISO 27002

Sécurité des Systèmes d'Information

Paul VEROT
Master II CNS-SR, 2026



UNIVERSITÉ ÉVRY
PARIS-SACLAY



UNIVERSITÉ ÉVRY

PARIS-SACLAY

Département d'informatique

univ-evry.fr

Titre:

Étude des services ISO 27002

Thème:

Sécurité des Systèmes d'Information

Groupe:

Master II CNS-SR

Participants:

Paul VEROT

Email:

20212888@etud.univ-evry.fr

pauljeanlouisverot@protonmail.com

Superviseur:

Damien PLOIX

Dépôt:

github.com/PaulVerot03/SSI

Nombre de pages:

14

Dernier changement:

18-09-2026

Note:

Le code pour générer ce document est disponible sur le dépôt GitHub, ainsi qu'un historique git.

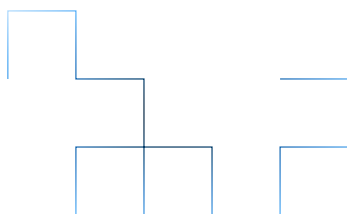
Résumé:

Une entreprise fictive, AlphaBeta, perd ses données de production suite à un déploiement raté chez son prestataire EvryTop. Ce document identifie les contrôles ISO 27002 qui auraient pu prévenir l'incident ou en limiter les effets, en évalue les conséquences juridiques et contractuelles, et confronte le cas à un incident réel comparable : la migration ratée de TSB Bank en 2018.

Table des matières

1 Contexte	2
1.1 Question	3
2 ISO 27002	4
2.1 Sauvegarde des Informations	5
2.2 Changement de Gestion	5
2.3 Ségrégation des environnement de developpement et production	5
3 Aspect Légal	7
4 Analyse d'un cas réel : TSB 2018	10
5 Conclusion	12
Références	14

Contexte



L'entreprise AlphaBeta, distributrice de dentifrice, emploie des VRP (Vendeurs/Représentant/Placiers) pour placer ses produits dans les grandes surfaces sur l'ensemble du territoire français. Elle souhaite mettre en place une solution de mobilité sur tablette et smartphone Android. Cette application permettra à chacun de ses vendeurs d'informer un système centralisé :

- du magasin dans lequel chaque vendeur se trouve,
- du niveau de stock présent dans les rayons.

Cette application traitera de données sensibles puisqu'elle permettra de calculer le chiffre d'affaire réalisé.

La réalisation, l'hébergement et l'exploitation de l'application est confiée à une jeune startup EvryTop créée par des étudiants de l'université d'Evry. À l'occasion de la mise en service de la nouvelle version de l'application, il s'avère que les données de production sont corrompues et qu'il est très difficile de récupérer les anciennes valeurs. Pour corriger le problème, il a été demandé à l'ensemble des vendeurs de réaliser une nouvelle saisie de leurs données. Exercice : Expliquez si les services ISO 27002 étudiés en cours auraient permis (ou pas) d'empêcher la situation de se produire ou d'en limiter les effets.

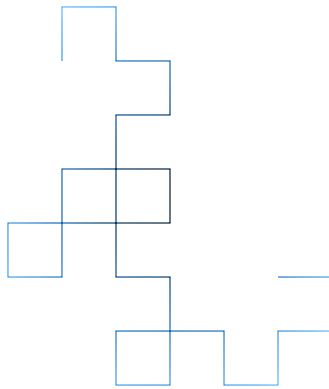
1.1 Question

Le déploiement d'une nouvelle version a corrompu les données de production, sans possibilité de restauration : les vendeurs ont dû ressaisir leurs données. L'incident touche l'intégrité et la disponibilité des données ; pas la confidentialité. Dont l'origine est les pratiques de changement, de test et de sauvegarde autour du déploiement.

La norme ISO 27002 distingue contrôles préventifs, de détection et correctifs. On peut donc diviser la question en deux :

- Quels contrôles auraient empêché la corruption des données ?
- Quels contrôles auraient limité ses effets une fois survenue ?

ISO 27002



La norme ISO 27002 définit plusieurs contrôles quant à l'intégrité des données et aux relations avec les entreprises tierces contractées pour ce genre de réalisation.

On peut isoler les éléments suivants :

2.1 Sauvegarde des Informations

Une simple sauvegarde des données aurait complètement annulé le problème.

La norme ISO indique :

A topic-specific policy on backup should be established to address the organization's data retention and information security requirements. Adequate backup facilities should be provided to ensure that all essential information and software can be recovered following an incident or failure or loss of storage media

[...]

c) storing the backups in a safe and secure remote location, at a sufficient distance to escape any damage from a disaster at the main site;

— 8.13 [1]

La norme recommande d'avoir plusieurs sauvegardes placées à des lieux différents pour éviter de toutes les pertes en cas d'événement grave (ex. tremblement de terre, inondation, ...).

ISO ne donne pas de recommandation pratique sur comment opérer ces systèmes de sauvegarde. Cependant, l'ANSSI [2] dispose d'un guide qui détaille, de manière non technique, les meilleures pratiques quant aux sauvegardes.

2.2 Changement de Gestion

La source spécifique de l'incident provient d'une entreprise tierce qui venait effectuer un service de migration. La norme décrit comment ces changements aux systèmes devraient être opérés.

Introduction of new systems and major changes to existing systems should follow agreed rules and a formal process of documentation, specification, testing, quality control and managed implementation. Management responsibilities and procedures should be in place to ensure satisfactory control of all changes.

Change control procedures should be documented and enforced to ensure the confidentiality, integrity and availability of information in information processing facilities and information systems, for the entire system development life cycle from the early design stages through all subsequent maintenance efforts.

— 8.32 [1]

Ici, la norme spécifie que les changements doivent être documentés et testés.

2.3 Ségrégation des environnements de développement et production

Le manque de séparation entre les environnements de productions et développement est probablement la source de l'irréversibilité de la corruption. Ce qui aurait dû être testé a été déployé en production.

Without adequate measures and procedures, developers and testers having access to production systems can introduce significant risks (e.g. unwanted modification of files or system environment, system failure, running unauthorized and untested code in production systems, disclosure of confidential data, data integrity and availability issues). There is a need to maintain a known and stable environment in which to perform meaningful testing and to prevent inappropriate developer access to the production environment.

— 8.31 [1]

Si EvryTop avait testé la migration sur un environnement de staging, la corruption aurait été détectée avant d'atteindre les données réelles des VRP.

8.31 est la condition préalable à ce que 8.29 et 8.32 soient réellement efficaces. Sans séparation, il n'y a pas d'environnement où tester.

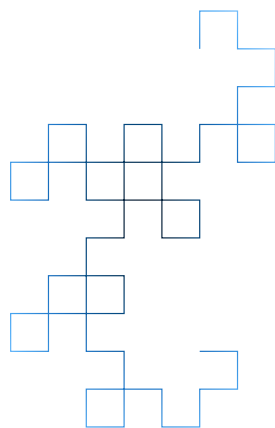
8.29*Security testing processes should be defined and implemented in the development life cycle.*

8.31*Development, testing and production environments should be separated and secured.*

8.32*Changes to information processing facilities and information systems should be subject to change management procedures.*

— ISO 27002 [1]

Aspect Légal



Avant-propos : bien qu'ayant suivi des cours de droit, je ne suis ni expert ni qualifié en matière de législation ; j'ai demandé à un ami avocat de relire cette partie.

L'entreprise EvryTop s'expose à des sanctions contractuelles et à une obligation de réparation.

Conformément à l'art. 1217 du Code civil, AlphaBeta peut refuser ou suspendre l'exécution de ses propres obligations (ici, le paiement des prestations), exiger une réduction du prix, ou demander la réparation des conséquences de l'inexécution, ces sanctions étant cumulables entre elles.

Dans ce contexte, il est probable qu'AlphaBeta suspende ses paiements le temps de la restauration et exige une réduction de prix ; EvryTop resterait tenue de restaurer les systèmes sans contrepartie financière additionnelle. AlphaBeta conserve également la possibilité de résilier le contrat et de faire intervenir un autre prestataire, aux frais d'EvryTop.

Concernant l'étendue des dommages-intérêts :

Le débiteur n'est tenu que des dommages et intérêts qui ont été prévus ou qui pouvaient être prévus lors de la conclusion du contrat, sauf lorsque l'inexécution est due à une faute lourde ou dolosive.

— art.1231-3 Code Civil [3]

EvryTop ne serait donc tenue que des dommages prévisibles au moment de la signature du contrat, sauf faute lourde ou dolosive¹. La question centrale devient alors la qualification de la faute : une erreur de configuration isolée relève de la faute ordinaire, tandis qu'une absence totale et connue de politique de sauvegarde pourrait être requalifiée en faute lourde, écartant le plafond de prévisibilité. Illustrant l'intérêt pratique du point 8.13 : une politique de sauvegarde formalisée et documentée est précisément ce qui permet à EvryTop de rester dans le spectre de la faute ordinaire plutôt que de la faute lourde.

Cette qualification devient déterminante si le contrat comporte une clause limitative de responsabilité. L'art. 1170 du Code civil indique :

Toute clause qui prive de sa substance l'obligation essentielle du débiteur est réputée non écrite.

— art.1170 Code Civil [3]

Ce principe est issu de l'arrêt Chronopost (Cass. com., 22 octobre 1996, n°93-18632)[4] : un prestataire qui s'engage sur un service précis ne peut prévoir une clause qui viderait cet engagement de tout contenu. Si le contrat EvryTop-AlphaBeta comportait une clause exonérant totalement EvryTop de toute responsabilité en cas de perte de données, cette clause serait réputée non écrite dès lors que l'intégrité des données constitue l'obligation essentielle du service commandé. Même en l'absence de clause explicite, les garanties ACID pourraient s'imposer au contrat comme usage professionnel, à condition qu'un tel usage soit reconnu comme notoire, constant et général.

Note : je n'ai pas trouvé suffisamment de contexte juridique pour étayer que les garanties ACID soient comptés comme «non-écrites».

¹Selon la jurisprudence de la Cour de cassation, la faute dolosive suppose que le débiteur choisisse délibérément de ne pas exécuter son obligation, peu important qu'il ait ou non cherché à nuire à son cocontractant.

Les contrats obligent non seulement à ce qui y est exprimé, mais encore à toutes les suites que leur donnent l'équité, l'usage ou la loi.

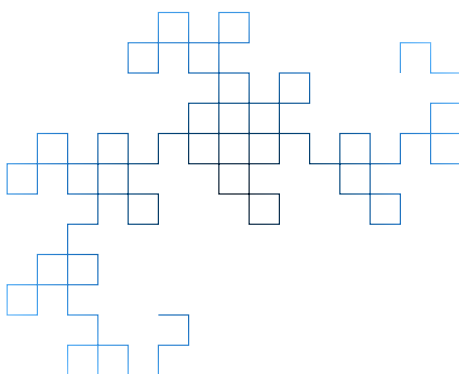
— art.1194 [3]

Où « l'usage » fait référence aux habitudes professionnelles ou locales d'un secteur s'imposant aux parties sans qu'il soit nécessaire de les inscrire.

Il faut néanmoins nuancer la responsabilité d'EvryTop selon la nature de son obligation de sauvegarde. L'obligation de moyens (mettre en oeuvre des mesures raisonnables) ou obligation de résultat (garantir l'absence de perte). Ce qui relève de l'interprétation du contrat ; l'art. 1231-1 du Code civil, qui conditionne la responsabilité du débiteur à l'absence de cause étrangère justifiant l'inexécution. Si AlphaBeta n'avait pas donné à EvryTop les moyens nécessaires à la mise en place de sauvegardes (accès, infrastructure, budget dédié), sa propre négligence pourrait être retenue comme cause d'exonération partielle.

Enfin, si les données corrompues comportaient des données à caractère personnel (ce qui est probable, la géolocalisation des VRP semble en constituer une), AlphaBeta serait alors tenue de notifier la CNIL sous 72h (art. 33 RGPD [5]).

Analyse d'un cas réel : TSB 2018



Un cas similaire a eut lieu en 2018 au Royaume-Uni (je n'ai pas trouvé de cas récent similaire en France, ce qui aurait été beaucoup plus intéressant au regard de la partie juridique précédente), où une migration des données des clients s'est mal passé résultant en une panne de plusieurs services pendant plusieurs mois.

La banque TSB voulait changer de plateforme, et a donc du migrer les données, cependant, bien que la migration se soit bien passée, des avaries techniques sont immédiatement apparues sur les nouveaux systèmes. Affectant plus de 5 millions de clients, il à fallut a TSB plus de deux trimestres pour rétablir complètement leurs services.

Two weeks after commencement of the migration, failures were still being reported with services such as the online banking application giving internal SQL database-related errors. Payment difficulties, particularly with business and mortgage accounts continued into a fourth week

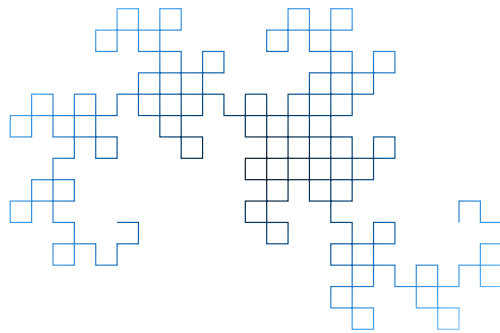
— BBC - TSB accused of “dreadful response” to meltdown

Les données étaient intact mais innaccessibles.

Cette panne a couté plus de £32.7m en dedomagements aux clients, £18.9m en amendes par la Prudential Regulation Authority, et £29.7m en amendes par la Financial Conduct Authority, élevant le coût total de la migration à £81.3m. [6]

La différence avec le cas AlphaBeta est qu'il existait des sauvegarde de données qui ont permis de rétablir l'accès aux services.

Conclusion



Pour répondre aux deux questions posées :

Empêcher la corruption relève des trois contrôles qui agissent en amont du déploiement : la séparation des environnements aurait fourni un espace de test représentatif de la production ; les tests de sécurité auraient validé la migration avant sa mise en service ; la gestion du changement aurait imposé une procédure documentée, avec plan de retour arrière, avant tout déploiement majeur. Ces trois contrôles agissent ensemble et leur absence conjointe est la cause la plus probable de l'incident.

La sauvegarde permet de limiter les effets à posteriori. C'est précisément ce qui différencie AlphaBeta du cas TSB analysé plus loin. TSB a subi une migration tout aussi ratée, mais disposait de sauvegardes fonctionnelles : les données sont restées intactes, seule leur disponibilité a été affectée le temps de la restauration. AlphaBeta, faute de sauvegarde testée, a perdu les données elles-mêmes, rendant la ressaisie manuelle inévitable.

Références

- [1] « Information security, cybersecurity and privacy protection – Information security controls ». [En ligne]. Disponible sur: <https://www.iso.org/standard/75652.html>
- [2] « Sauvegarde des systèmes d'information – Les fondamentaux ». Consulté le: 18 septembre 2026. [En ligne]. Disponible sur: <https://cyber.gouv.fr/publications/fondamentaux-sauvegarde-systemes-dinformation>
- [3] « Code civil ». Consulté le: 18 septembre 2026. [En ligne]. Disponible sur: https://www.legifrance.gouv.fr/codes/texte_lc/LEGITEXT000006070721
- [4] C. commerciale Cour de cassation, « Arrêt n°93-18.632, société Banchereau c/ société Chronopost ». [En ligne]. Disponible sur: <https://www.legifrance.gouv.fr/juri/id/JURITEXT000007035966/>
- [5] « Règlement (UE) 2016/679 du 27 avril 2016 relatif à la protection des personnes physiques à l'égard du traitement des données à caractère personnel et à la libre circulation de ces données (RGPD) ». [En ligne]. Disponible sur: <https://eur-lex.europa.eu/eli/reg/2016/679/oj>
- [6] « TSB fined £48.65m for operational resilience failings | FCA ». Consulté le: 18 septembre 2026. [En ligne]. Disponible sur: <https://www.fca.org.uk/news/press-releases/tsb-fined-48m-operational-resilience-failings>
- [7] « TSB accused of 'dreadful response' to meltdown ». Consulté le: 18 septembre 2026. [En ligne]. Disponible sur: <https://www.bbc.com/news/business-44121901>